

SecCore Essentials - Network Layer Security



seccore.at/blog/network-layer-security

Benjamin Floriani, Patrick Pongratz

September 29, 2025



Summary

This blog post highlights essential security controls for the network layer in enterprise environments. The network layer plays a crucial role in preventing attackers from moving laterally and limiting the impact of breaches. In order to implement this SecCore Essential and protect against common attacks, the following settings should be enforced:

- At least the following VLANs should be implemented:
 - Office VLAN: Standard user endpoints (clients, workstations, laptops)
 - Untrusted Devices VLAN: Printers, IoT devices etc.
 - Server VLAN: Services such as file servers, application servers and databases
 - Management VLAN: Administrative systems such as monitoring platforms, jump hosts and management interfaces
 - DMZ VLAN (if applicable): Systems reachable from external networks (e.g., public web servers, mail gateways, VPN endpoints)

- At least the following stateful firewall Access Control Lists (ACLs) between these VLANs should be configured:
 - Server VLAN → Office VLAN: DENY all connections
Servers cannot initiate sessions toward clients
 - Untrusted Devices VLAN → Any VLAN: DENY all connections
Traffic must be restricted to explicitly approved services, such as print servers.
 - Office VLAN → Management VLAN: DENY all connections
End-user systems cannot access management infrastructure
 - DMZ VLAN → Any VLAN: DENY all connections
DMZ systems cannot initiate traffic into internal networks
 - Office VLAN → Server VLAN: ALLOW only strictly necessary traffic
Application-specific ports and protocols are required for business operations
- Network Access Control (NAC) based at least on MAC-addresses should be implemented.

Introduction

The network layer connects all devices in an organization. Several important measures need to be implemented in order to stop attacks from reaching sensitive systems such as backup or financial servers.

Common Attack Vectors

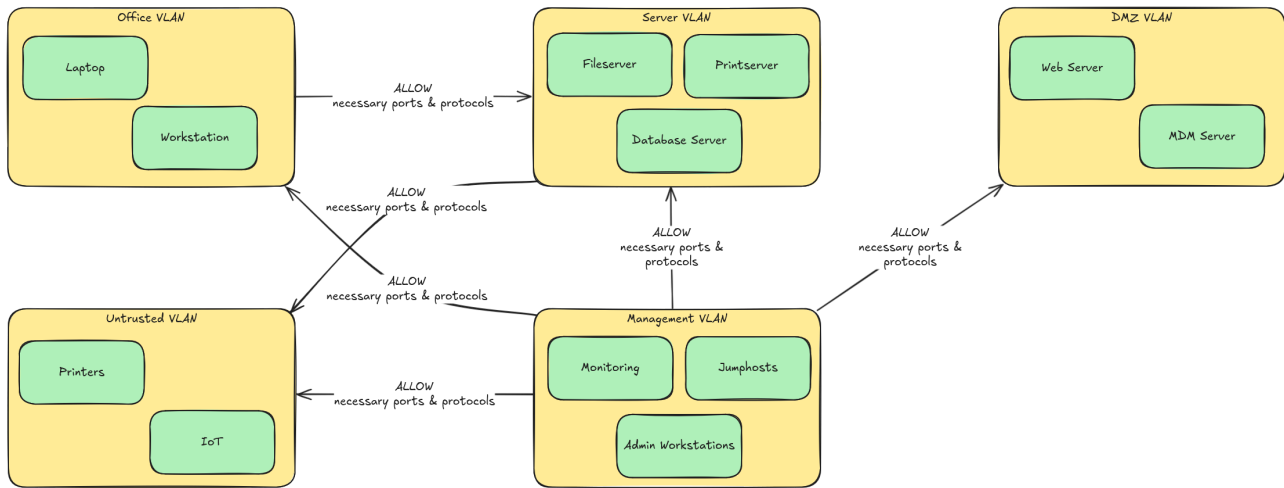
The following sections describe common attack vectors on the network layer.

Missing Network Segmentation and ACLs

Without network segmentation and Access Control Lists, attackers can easily move between devices and systems within the network. This lack of separation allows threats such as ransomware to spread quickly, increasing the risk of data breaches and unauthorized access.

Sensitive resources are exposed to unnecessary risk and malicious actors can exploit vulnerabilities across multiple systems with minimal resistance. This is especially critical for devices that are accessible from outside the network, such as web servers, which are under constant attack from the internet and may be compromised by just a single successful exploit.

A sensible network segmentation approach could look like this:



Note: A general DENY rule is implied here, only connections that are allowed are in this diagram.

Missing Network Access Control

When no modern Network Access Control solution is implemented, attackers or even unwitting employees can easily connect malicious devices to the internal network. In environments where network ports are readily accessible, attackers can conduct attacks remotely by connecting a device that provides remote access to the network.

There are usually two possible methods of implementing NAC: By using MAC addresses or via certificates over 802.1x.

A MAC address based solution offers little protection against malicious attackers, but can help against employees trying to plug in their own routers or other devices. MAC addresses can easily be copied by a knowledgeable person, thereby bypassing this form of NAC.

A NAC implemented using certificates is a much stronger solution since an attacker would first need to obtain a valid device certificate. While 802.1x is not completely secure, exploiting it requires significant preparation and cannot be done easily or 'on the fly', so it is considered secure for most scenarios.

Attack Scenario

This section should demonstrate how attackers exploit missing network layer segmentation. The setup of this attack scenario is as follows:

- Network segmentation is not configured, every device is in the same VLAN
- Network Access Control with MAC address filtering is implemented
- The attacker has a foothold in the internal network without credentials
- The attacker has no considerations regarding OPSEC, the most straightforward approach is used

The attacker has gained a foothold in the internal network via MAC address spoofing of a disconnected printer:

```
kali@kali ~ [1]> sudo macchanger -m [REDACTED] eth0
[sudo] password for kali:
Current MAC: [REDACTED]
Permanent MAC: [REDACTED]
```

Since no network segmentation is in place they now have access to the entire internal network, including sensitive servers and management systems. This access can be used to scan the network to identify other devices using **Nmap**¹:

```
Nmap scan report for 192.168.30.138
Host is up (0.0040s latency).
Not shown: 994 closed ports
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 9.2p1 Debian 2+deb12u5 (protocol 2.0)
80/tcp    open  http         nginx
|_http-title: openmediavault Workbench
111/tcp   open  rpcbind      2-4 (RPC #100000)
| rpcinfo:
|   program version  port/proto  service
|   100000  2,3,4    111/tcp    rpcbind
|   100000  2,3,4    111/udp    rpcbind
|   100000  3,4      111/tcp6   rpcbind
|_  100000  3,4      111/udp6   rpcbind
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
5357/tcp  open  http         BaseHTTPServer 0.6 (Python 3.11.2)
|_http-server-header: BaseHTTP/0.6 Python/3.11.2
|_http-title: Error response
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_nbstat: NetBIOS name: OPENMEDIAVAULT, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb2-security-mode:
|   2.02:
|_    Message signing enabled but not required
| smb2-time:
|   date: 2025-09-11T10:35:01
|_  start_date: N/A
```

This revealed other interesting devices, such as a system called `openmediavault.lab.local`. This is a NAS system running the open-source software OpenMediaVault. The attacker can now try to access this system using default credentials, which are publicly available on the internet:



After logging in into the NAS system, the configurations can be examined. This revealed an installed backup task which was configured with the domain administrator's credentials:

🏠 Services Rsync Tasks				
+ ✎ ▶ 🗑				
Enabled ▾	Scheduling	Type ▾	Source ^	Destination ▾
✓	At 07:37 AM	Remote	BackupShare	administrator@192.168.30.131:/backu

When opening the backup task, the domain administrator's password can be seen in cleartext:

Services | Rsync | Tasks | Edit

BackupShare [on /dev/sda1, BackupShare/]

Destination server
administrator@192.168.30.131:/backup

The destination remote server, e.g. [USER@]HOST-DEST, [USER@]HOST::DEST or

Authentication
Password

Password

These credentials can now be used with tools such as **NetExec**² to gain access to the domain controller:

```
bf@DESKTOP-K7TUEGS ~-> nxc smb 192.168.30.131 -d lab.local -u administrator -p [REDACTED]
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [*] Windows Server 2022 Build 20348 x64 (name:WIN-4SAHM65HN1H) (doma
in:lab.local) (signing:True) (SMBv1:False) (Null Auth:True)
SMB 192.168.30.131 445 WIN-4SAHM65HN1H [+] lab.local\administrator:[REDACTED] (Pwn3d!)
```

Mitigation

When the above-mentioned security controls are implemented, the attack would have been mitigated in the following ways:

- The attacker would not have been able to connect to the internal network without valid credentials, since a NAC solution with 802.1x would have been in place.
- Even if the attacker had managed to connect to the internal network, they would not have been able to access the NAS system, since network segmentation and ACLs would have prevented this.
- The attacker would not have been able to access the domain controller, since the NAS system would not have domain administrator credentials stored in its configuration.